🔐 Lab 3 – SecurePass Telecom
Kimlik Doğrulama ve Active Directory Güvenlik Denetimi Deneyimi

Senaryo

Bir bilgi sistemleri denetçisi olarak SecurePass Telecom şirketinin merkezi kimlik doğrulama ve Active Directory altyapısını denetlemek üzere görevlendirildiniz.
Denetim planlama toplantılarında sistem sahipleri aşağıdaki güvenceyi vermiştir:

- Parola politikaları sektör standartlarına uygundur.
- Tüm kullanıcılar güçlü parola kullanmaktadır.
- Ayrıcalıklı hesaplar düzenli olarak gözden geçirilmektedir.
- MFA kritik hesaplarda aktif durumdadır.
- Servis hesapları güvenli şekilde yönetilmektedir.
- Kullanılmayan hesap bulunmamaktadır.
- Eski çalışan hesapları kaldırılmıştır.
- Domain Admin yetkileri minimum seviyededir.
- Kimlik doğrulama logları düzenli olarak incelenmektedir.
- Hash algoritmaları güvenlidir.
- Kerberos yapılandırmaları güvenlidir.

Sistem sahiplerine göre ortamda herhangi bir güvenlik riski bulunmamaktadır.
Ancak bir denetçi olarak yalnızca beyanlara güvenmek yerine teknik doğrulama yapmanız beklenmektedir.
Bu amaçla aşağıdaki kanıtlar tarafınıza sağlanmıştır.
Göreviniz:

- Kimlik doğrulama kontrollerini değerlendirmek
- Parola güvenliğini analiz etmek
- Ayrıcalıklı erişimleri incelemek
- Active Directory risklerini belirlemek
- Bulguları kanıtlarıyla desteklemek
- Profesyonel bir denetim raporu hazırlamak

Sağlanan Kanıtlar

users.csv

Username	Type	Department
administrator	Built-in	IT
domainadmin	Privileged	IT
helpdesk	Privileged	IT
backupsvc	Service	IT
sqlsvc	Service	DBA
legacysvc	Service	IT
developer	User	IT
finance.manager	User	Finance

hr.manager	User	HR
tempconsultant	External	External
oldadmin	Disabled	Unknown
intern2024	User	HR

password_policy.txt

Minimum Password Length : 8
Password History : 3
Maximum Password Age : 365 Days
Minimum Password Age : 0
Complexity Required : Disabled
Lockout Threshold : 0
Lockout Duration : 0
Store Password Using Reversible Encryption : Enabled

mfa_report.csv

User	MFA Enabled
administrator	No
domainadmin	No
helpdesk	No
backupsvc	No
sqlsvc	No
developer	Yes
finance.manager	Yes
hr.manager	No
tempconsultant	No

service_accounts.csv

Account	Last Password Change
backupsvc	2019-03-04
sqlsvc	2020-11-12
legacysvc	2018-07-21
applinksvc	Never
syncsvc	Never

privileged_accounts.csv

administrator
domainadmin
helpdesk
backupsvc
sqlsvc

privileged_review.txt

administrator

Owner: Unknown
domainadmin
Owner: Unknown
helpdesk
Owner: IT Operations
backupsvc
Owner: Unknown
sqlsvc
Owner: DBA Team

login_audit.log

2026-03-01 admin login success from 10.10.10.5
2026-03-01 admin login success from 185.22.44.8
2026-03-01 admin login success from 185.22.44.8
2026-03-01 admin login success from 185.22.44.8
2026-03-01 helpdesk login success from 103.81.25.11
2026-03-01 administrator login success from 103.81.25.11
2026-03-01 backupsvc login success from 103.81.25.11
2026-03-01 sqlsvc login success from 103.81.25.11

NTLM Hash İncelemesi

ntlm_hashes.txt

administrator:
aad3b435b51404eeaad3b435b51404ee:
31d6cfe0d16ae931b73c59d7e0c089c0
domainadmin:
aad3b435b51404eeaad3b435b51404ee:
58a478135a93ac3bf058a5ea0e8fdb71
backupsvc:
aad3b435b51404eeaad3b435b51404ee:
32ed87bdb5fdc5e9cba88547376818d4
sqlsvc:
aad3b435b51404eeaad3b435b51404ee:
b4b9b02e6f09a9bd760f388b67351e2b
helpdesk:
aad3b435b51404eeaad3b435b51404ee:
8846f7eaee8fb117ad06bdd830b7586c
tempconsultant:
aad3b435b51404eeaad3b435b51404ee:
fcea920f7412b5da7be0cf42b8c93759
developer:
aad3b435b51404eeaad3b435b51404ee:
25d55ad283aa400af464c76d713c07ad

MD5 Hash İncelemesi

md5_hashes.txt

admin:
5f4dcc3b5aa765d61d8327deb882cf99
developer:
e10adc3949ba59abbe56e057f20f883e
backupsvc:
0d107d09f5bbe40cade3de5c71e9e9b7
helpdesk:
21232f297a57a5a743894a0e4a801fc3
finance:
25f9e794323b453885f5181f1b624d0b

SHA256 Hash İncelemesi

sha256_hashes.txt

finance.manager:
ef92b778bafe771e89245b89ecbc08a44a4e166c06659911881f383d4473e94f
hr.manager:
8d969eef6ecad3c29a3a629280e686cff8fabdcb5a693e4f4f3b5e7f7b4e5d53
sqlsvc:
5e884898da28047151d0e56f8dc6292773603d0d6aabbdd38f4f2f4f4f4f4f4f
legacysvc:
6ca13d52ca70c883e0f0bb101e425a89e8624de51db2d2392579b98c1d4c2d8
f

Kerberoasting Kanıtları

spn_accounts.txt

MSSQLSvc/sql01.securepass.local
sqlsvc
HTTP/intranet.securepass.local
websvc
HTTP/legacy.securepass.local
legacysvc
MSSQLSvc/db-prod.securepass.local
backupsvc

kerberoast_hashes.txt

$krb5tgs$23$*sqlsvc$SECUREPASS.LOCAL...
$krb5tgs$23$*backupsvc$SECUREPASS.LOCAL...
$krb5tgs$23$*legacysvc$SECUREPASS.LOCAL...
$krb5tgs$23$*websvc$SECUREPASS.LOCAL...

AS-REP Roasting Kanıtları

asrep_users.txt

legacyuser
oldadmin
migrationaccount

svc_backup
tempconsultant

asrep_hashes.txt

$krb5asrep$23$legacyuser@SECUREPASS.LOCAL...
$krb5asrep$23$oldadmin@SECUREPASS.LOCAL...
$krb5asrep$23$migrationaccount@SECUREPASS.LOCAL...
$krb5asrep$23$tempconsultant@SECUREPASS.LOCAL...

Domain Admin Üyelikleri

domain_admins.txt

administrator
domainadmin
backupsvc
helpdesk
sqlsvc
tempconsultant

Kullanıcı Yaşam Döngüsü İncelemesi

leaver_accounts.csv

User	Last Login
oldadmin	532 gün
contractor01	741 gün
intern2024	680 gün
tempconsultant	194 gün
legacyuser	881 gün

Beklentiler

Denetim sırasında aşağıdaki başlıkları değerlendiriniz:

1. Parola Politikaları
2. Hesap Kilitleme Mekanizmaları
3. MFA Yapısı
4. Hash Güvenliği
5. NTLM Riskleri
6. MD5 Kullanımı
7. SHA256 Kullanımı
8. Ayrıcalıklı Hesap Yönetimi
9. Domain Admin İncelemesi
10. Service Account Güvenliği
11. Kerberoasting Riskleri
12. AS-REP Roasting Riskleri
13. Eski Çalışan Hesapları
14. IAM Süreçleri
15. Yetki Gözden Geçirme Süreçleri
16. Kimlik Doğrulama Logları

17. Şüpheli Giriş Denemeleri
18. Shared Account Riskleri
19. Least Privilege Prensibi
20. Active Directory Güvenlik Olgunluğu

Bonus Görev

Bir saldırgan yalnızca backupsvc hesabını ele geçirirse:

- Domain Admin olabilir mi?
- Kerberoasting mümkün mü?
- Lateral Movement yapabilir mi?
- Privilege Escalation gerçekleştirebilir mi?
- Tüm domain ele geçirilebilir mi?

Teknik olarak değerlendiriniz.

Teslimat

Çalışma sonunda yalnızca bu ortama özel kısa bir denetim raporu hazırlayın.
Raporda aşağıdaki bölümler bulunmalıdır:

- Yönetici Özeti
- Denetim Kapsamı
- Yapılan Testler
- Tespit Edilen Bulgular
- Risk Değerlendirmesi
- Öneriler

Önemli Not

Bu laboratuvar çalışması eğitim amacıyla hazırlanmıştır.
Lab ortamında yer alan kullanıcılar, hashler, servis hesapları, Active Directory nesneleri, loglar, IP adresleri ve tüm veriler eğitim amacıyla oluşturulmuştur.
Amaç katılımcıların gerçek dünyada karşılaşabilecekleri parola güvenliği, kimlik doğrulama, Active Directory ve erişim yönetimi denetimlerini kontrollü bir ortamda deneyimlemelerini sağlamaktır.